Strecht Simulados

Resumo de bolso SC-500

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

300	6	70%
questões no curso	provas completas	nota de corte

Como é a prova SC-500



Material independente de preparação, sem afiliação ou endosso de Microsoft. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame SC-500?

Treine com as 300 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Proteger armazenamento, bancos de dados e redes

- On-premises para ponto de extremidade privado: encaminhador condicional da zona pública para o endpoint de entrada do resolvedor.
- Regra por camada sem IP fixo = ASG como origem/destino na regra de NSG (NICs na mesma VNet).
- Saída só para o Storage da região: permitir a marca regional (ex.: Storage.BrazilSouth) antes e negar Internet depois.
- Entra-only no Azure SQL só é habilitado depois de definir o administrador do Microsoft Entra.
- Virtual WAN Basic = só S2S; hub protegido e P2S exigem Standard (upgrade sem volta).
- Regra de rede permissiva anula bloqueio de FQDN em regra de aplicativo: rede é avaliada antes.
- IP externo só para um banco: regra de firewall no nível do banco via T-SQL.
- FQDN em regra de rede do Azure Firewall: proxy DNS ligado e VNets usando o firewall como DNS.

Proteger a computação

- AKS sem credencial estática: Azure RBAC para Kubernetes + contas locais desabilitadas.
- ACI puxando do ACR com identidade: tem de ser atribuída pelo usuário, com AcrPull.
- Pull de imagem sem senha = identidade gerenciada com AcrPull e usuário administrador desabilitado.
- Alerta de jailbreak em modelos do Foundry = plano AI services do Defender for Cloud.
- Bloquear colagem de dado sensível em site de IA = DLP de endpoint + dispositivo integrado + extensão do Purview.
- Gatilho do Logic Apps só com token do Entra = política de autorização + SAS desativada.
- Até onde vai o estrago de um agente comprometido = caminhos de ataque e raio de alcance no Exposure Management.
- APIM para Foundry sem chave = identidade gerenciada + authentication-managed-identity + OpenAI User.

Gerenciar identidade, acesso e governança

- Revisor do admin consent workflow sem função administrativa vê e nega, mas não aprova.
- Wrap/unwrap para CMK = Key Vault Crypto Service Encryption User; Contributor é plano de controle.
- Segunda aprovação para mexer em segurança do backup = MUA com Resource Guard (de preferência em outro locatário).
- Renovação automática no Key Vault: CA parceira (DigiCert/GlobalSign) ou autoassinado, com a ação autoRenew.
- Rotação automática de chave = rotation policy; aviso antes de vencer = KeyNearExpiry no Event Grid.

- Só associar uma identidade atribuída pelo usuário existente: Managed Identity Operator no escopo da identidade.
- Herdado não se remove no filho: vá ao escopo de origem (Check access mostra qual).
- Grupo que concede vários acessos e precisa virar just-in-time: PIM for Groups com associação qualificada.

Gerenciar e monitorar a postura de segurança

- Restringir plug-ins da Microsoft no Security Copilot = configuração de owner, disponibilidade só para owners.
- Residência de dados por país = um workspace por região exigida.
- Evolução da conformidade = pasta de trabalho Compliance Over Time.
- Prioridade de exposição externa no EASM = insights de severidade alta no Resumo da superfície de ataque.
- Regras de automação: sequenciais, pela ordem, e cada uma vê as mudanças das anteriores.
- Pergunta contextual (exposta + vulnerável + com permissão) = explorador de segurança na nuvem do Defender CSPM.
- Solução instalada não cria incidente sozinha: crie as regras a partir dos modelos.
- Compartilhamento de dados do Security Copilot: vem ligado e quem desliga é o proprietário.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Proteger a computação

Uma rede de farmácias vai criar novas VMs Linux e precisa que discos temporários e caches de disco também fiquem criptografados, sem consumir CPU da VM com dm-crypt. A solução usada até agora, o Azure Disk Encryption, tem aposentadoria marcada para 15 de setembro de 2028. O que habilitar nas novas VMs?

A. Criptografia no host (encryption at host)
B. Azure Disk Encryption com dm-crypt e chave no Key Vault
C. Criptografia de disco confidencial em VM do tipo padrão
D. A criptografia padrão do lado do servidor (SSE)

Questão 2 · Proteger armazenamento, bancos de dados e redes

O DBA da Rede Escolar Saber revisou os achados da avaliação de vulnerabilidades do Defender for Azure SQL, em configuração expressa. Algumas permissões apontadas são intencionais. Ele quer que essas regras apareçam como aprovadas nas próximas verificações, a menos que algo mude. O que fazer?

A. Isentar o banco de dados inteiro da recomendação de vulnerabilidades do Defender for Cloud
B. Definir esses resultados como linha de base, que na configuração expressa vale na hora
C. Voltar para a configuração clássica, que oculta automaticamente os achados repetidos
D. Remover as regras correspondentes da iniciativa do Azure Policy atribuída ao servidor

Questão 3 · Proteger armazenamento, bancos de dados e redes

Os Laticínios Serra Gaúcha restringiram uma conta de armazenamento a redes selecionadas. Um workspace específico do Azure Synapse, que não está em nenhuma VNet permitida, precisa ler os dados com a própria identidade gerenciada, e nenhum outro workspace do locatário deve ganhar acesso de rede à conta. O que configurar?

A. A exceção Permitir serviços confiáveis da Microsoft no firewall, mais uma função de dados no contêiner
B. Uma regra de instância de recurso para esse workspace, mais uma função de dados para a identidade dele
C. Uma regra de IP com a marca de serviço do Synapse no firewall da conta de armazenamento de destino
D. Uma política de acesso armazenada no contêiner que restrinja o acesso ao identificador do workspace

Questão 4 · Proteger armazenamento, bancos de dados e redes

A Corretora Horizonte Azul quer impedir que um servidor lógico do Azure SQL Database envie dados (por auditoria, importação e exportação ou OPENROWSET) para contas de armazenamento que não sejam as da própria empresa. O que configurar?

A. Restringir a rede de saída do servidor e listar os FQDNs das contas de armazenamento permitidas
B. Negar o acesso à rede pública do servidor e criar um ponto de extremidade privado na VNet
C. Habilitar a autenticação somente Microsoft Entra no servidor lógico e remover os logins SQL
D. Criar regras de firewall de entrada no nível do servidor com os IPs públicos das redes da empresa e dos parceiros

Questão 5 · Gerenciar identidade, acesso e governança

Na Agropecuária Cerrado Verde, os novos colaboradores devem começar sem senha e registrar uma passkey no Microsoft Authenticator logo no primeiro dia. A identidade do colaborador é conferida presencialmente pelo suporte, que entrega a credencial inicial. Qual credencial emitir e qual função administrativa pode emiti-la para um usuário comum?

A. Temporary Access Pass, emitido por um Administrador de Usuários do locatário
B. Temporary Access Pass, emitido por um Administrador de Autenticação
C. Senha temporária com troca obrigatória no primeiro acesso ao portal
D. Senha de aplicativo (app password) gerada no portal pelo time de suporte

Questão 6 · Proteger a computação

A API de cotação da seguradora Atlas, publicada no API Management no nível Standard v2, precisa limitar cada assinante a 20 chamadas a cada 60 segundos para conter picos e bloquear um intervalo de IPs abusivo. Quais políticas usar?

A. quota-by-key com período de 60 segundos e ip-filter com action allow
B. rate-limit-by-key por assinatura e ip-filter com action forbid
C. quota-by-key com período de 60 segundos e validate-azure-ad-token
D. validate-jwt com claim de IP e rate-limit-by-key pelo IP do gateway

Questão 7 · Gerenciar identidade, acesso e governança

A software house Nimbus registrou no próprio locatário um aplicativo multilocatário de gestão de frotas. Três clientes já o usam após consentir. Um cliente pergunta onde o aplicativo aparece no locatário dele e o que foi criado ali no momento do consentimento. Qual resposta está correta?

A. Nada é criado no locatário do cliente, pois o token é emitido pelo locatário de origem da Nimbus
B. Uma identidade gerenciada atribuída pelo usuário, criada para representar o aplicativo no locatário
C. Uma cópia do objeto de aplicativo, exibida em Registros de aplicativo, com os mesmos segredos do cliente
D. Uma entidade de serviço, em Aplicativos empresariais; o objeto de aplicativo fica no locatário da Nimbus

Questão 8 · Proteger armazenamento, bancos de dados e redes

No data lake da Agro Analytics (ADLS Gen2), a equipe removeu da ACL do diretório /financeiro a permissão de leitura de um analista, mas ele continua lendo os arquivos. Ele tem a função Storage Blob Data Reader na conta. Qual é a causa?

A. A ACL padrão do diretório pai sobrescreve a ACL de acesso definida no diretório filho
B. As ACLs POSIX se aplicam a arquivos, e não a diretórios, no Data Lake Storage Gen2
C. As alterações de ACL levam 24 horas para propagar em contas com namespace hierárquico
D. A atribuição RBAC é avaliada antes e, quando concede o acesso, as ACLs não são consultadas

Questão 9 · Proteger armazenamento, bancos de dados e redes

A Gráfica Ipiranga entrega SAS a parceiros para baixar arquivos de um contêiner. Depois que um SAS vazou, a equipe percebeu que só conseguiria invalidá-lo rotacionando a chave da conta, o que derrubou outros sistemas. Que abordagem permitiria revogar SAS emitidos sem trocar a chave?

A. SAS de conta vinculados a uma política de acesso armazenada na própria conta
B. SAS de conta com restrição de IP de origem e protocolo exigindo HTTPS
C. SAS de serviço vinculados a uma política de acesso armazenada no contêiner
D. SAS de serviço com permissão de leitura e validade de um ano inteiro

Questão 10 · Gerenciar identidade, acesso e governança

O auditor da Fintech Capital pediu duas evidências: o status atual da assinatura de produção frente ao PCI DSS e os relatórios de certificação da própria Microsoft (como SOC e ISO) para a nuvem do Azure. Onde o engenheiro obtém ambos no Defender for Cloud?

A. Na exportação contínua para o Log Analytics e em consultas KQL salvas como pastas de trabalho
B. Na exportação da pontuação segura pela API REST e no relatório de recomendações do Azure Advisor
C. Na opção Baixar relatório do painel de conformidade regulatória e na guia Relatórios de auditoria
D. No relatório de conformidade do Azure Policy e em um chamado de suporte pedindo os certificados

Gabarito comentado

1. A) Criptografia no host (encryption at host)
Substituta do Azure Disk Encryption que cobre disco temporário e cache = criptografia no host.

2. B) Definir esses resultados como linha de base, que na configuração expressa vale na hora
Achado aceito na VA do SQL = linha de base (expressa: efeito imediato).

3. B) Uma regra de instância de recurso para esse workspace, mais uma função de dados para a identidade dele
Firewall do Storage para um recurso específico de outro serviço = regra de instância de recurso + RBAC.

4. A) Restringir a rede de saída do servidor e listar os FQDNs das contas de armazenamento permitidas
Evitar exfiltração pelo próprio servidor SQL = regras de firewall de saída com FQDNs permitidos.

5. B) Temporary Access Pass, emitido por um Administrador de Autenticação
Integrar usuário direto em sem senha = Temporary Access Pass.

6. B) rate-limit-by-key por assinatura e ip-filter com action forbid
Pico curto = rate-limit-by-key; volume no período = quota-by-key; bloquear IP = ip-filter forbid.

7. D) Uma entidade de serviço, em Aplicativos empresariais; o objeto de aplicativo fica no locatário da Nimbus
Registro de aplicativo = objeto global no locatário de origem; aplicativo empresarial = entidade de serviço em cada locatário.

8. D) A atribuição RBAC é avaliada antes e, quando concede o acesso, as ACLs não são consultadas
ADLS Gen2: RBAC vence antes da ACL; para granularidade por pasta, não dê função de dados ampla.

9. C) SAS de serviço vinculados a uma política de acesso armazenada no contêiner
Revogar SAS sem trocar chave = política de acesso armazenada (vale para SAS de serviço).

10. C) Na opção Baixar relatório do painel de conformidade regulatória e na guia Relatórios de auditoria
Evidência para auditor: Baixar relatório (status do padrão) + Relatórios de auditoria (certificações da Microsoft).

Pronto para o exame SC-500?

Treine com as 300 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →